COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.4 · Denial of Service

Mestre CyberSec · **Lesson 2.4 — Denial of Service** (6:07) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: DoS (uma origem) derruba serviço; DDoS (distribuído — botnet de milhares de máquinas). Técnicas: amplification (requisição GRANDE pra servidor aberto que amplifica); SYN flood (meio handshake TCP deixa conexões penduradas); ICMP/ping flood. Defesa: CDN (Cloudflare/Akamai na frent

💡 Key Exam Highlights & Critical Concepts

- DoS/DoS: uma origem; DDoS: botnet de milhares — amplifica
- Amplification attack: req de 50 bytes gera resposta de 4000 (DNS/NTP abertos)
- Defesa principal: CDN / CloudFlare — absorve na borda antes de chegar

🎯 Exam Tips & Typical CompTIA Scenarios

- 'thousands of machines send traffic simultaneously' = DDoS
- 'uses DNS or NTP servers to amplify traffic' = amplification attack

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.4 — Denial of Service)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Denial of Service (DoS)

An attack launched from a single source that floods a service with traffic or exploits a weakness to make it unavailable to legitimate users.

⚠️ ***Exam Trap:*** *Se o enunciado diz 'single source', 'one machine' ou 'uma única origem', a resposta é DoS — nunca DDoS.*

• Distributed Denial of Service (DDoS)

A coordinated DoS attack originating from thousands of compromised hosts simultaneously, making it very difficult to block by a single source IP.

⚠️ ***Exam Trap:*** *Gatilho clássico: 'thousands of machines send traffic simultaneously' = DDoS (e normalmente envolve botnet).*

• Botnet

A network of compromised devices (bots or zombies) remotely controlled by a command-and-control (C2) server and used to launch DDoS, spam, or crypto-mining campaigns.

⚠️ ***Exam Trap:*** *Botnet é a FONTE do DDoS; os dispositivos infectados pertencem a terceiros, por isso bloquear por IP quase nunca funciona.*

• Amplification Attack (Reflection)

An attack that sends a small spoofed request to an open third-party server (DNS, NTP, ICMP broadcast) so its much larger response is sent to the victim.

⚠️ ***Exam Trap:*** *'Pequena requisição gera resposta enorme' ou 'uses DNS or NTP servers to amplify traffic' = amplification/reflection attack (ex.: 50 bytes → 4000 bytes).*

• SYN Flood

A TCP DoS attack that sends many SYN packets with spoofed source addresses, filling the connection backlog with half-open sessions until real clients cannot connect.

⚠️ ***Exam Trap:*** *'Half-open TCP handshake deixando conexões penduradas' = SYN flood; defesa-chave: SYN cookies / firewalls stateful.*

• ICMP Flood (Ping Flood)

A volume-based attack that overwhelms a target with ICMP Echo Request packets, consuming bandwidth and processing resources until the service degrades.

⚠️ ***Exam Trap:*** *ICMP/ping flood é ataque VOLUME-based (banda); distinga do SYN flood, que é de PROTOCOLO/estado (esgota a tabela de conexões).*

• Content Delivery Network (CDN)

A geographically distributed set of edge servers that cache content and absorb/filter malicious traffic at the border before it reaches the origin server.

⚠️ ***Exam Trap:*** *Defesa principal de DDoS citada pelo Messer: CDN (Cloudflare/Akamai) absorve na borda — a origem nunca vê o volume total do ataque.*

• Rate Limiting

A mitigation control that caps the number of requests accepted from a source or per session, reducing the impact of flooding and brute-force traffic.

⚠️ ***Exam Trap:*** *Complemento da CDN/WAF na defesa contra DoS: se a questão fala em 'limitar requisições por origem', pense em rate limiting, não em criptografia.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 DoS vs. DDoS & The Botnet Army

🏠 **Real-World Analogy:** A DoS (Denial of Service) attack is like a single prank caller dialing a pizzeria's phone line nonstop to keep it continuously busy, preventing legitimate customers from placing orders. A DDoS (Distributed Denial of Service) is when that adversary commands a 50,000-strong army of compromised IoT devices (a Botnet) to dial every phone line simultaneously. The switchboard collapses under the influx. Blocking a single incoming caller is futile because the traffic floods in from thousands of distinct global IP addresses.

🔍 **Root Cause & Background:** Compute, memory, and transit bandwidth are finite resources. Threat actors compromise poorly defended IoT hardware and endpoints using default credentials, building large-scale botnets coordinated by Command and Control (C2) servers to blast distributed traffic.

🛡️ **GRC Auditor Perspective:** Procure cloud-based DDoS scrubbing and mitigation solutions (Cloudflare, AWS Shield, Akamai); implement resilient multi-region load balancers; and establish Business Continuity Plans (BCP) with tight recovery time objectives (RTO).

⚠️ **How CompTIA Tests This:** Trigger: 'traffic overwhelming a target originates from thousands of distributed compromised endpoints coordinated by C2' -> DDoS / Botnet. If from a single host: DoS.

📌 SYN Flood & TCP 3-Way Handshake Exploitation

🏠 **Real-World Analogy:** It is like a patron approaching a bank teller and extending a hand to initiate a greeting (SYN). The teller cheerfully extends a hand back (SYN-ACK) waiting for the customer to shake hands and complete the greeting (ACK). Instead, the visitor turns around and freezes in place. The teller must hold their hand out until a timer expires. When a thousand bogus visitors do this simultaneously, every teller is paralyzed with outstretched hands, blocking real customers from reaching the counter.

🔍 **Root Cause & Background:** TCP connection establishment demands the SYN -> SYN-ACK -> ACK handshake. Upon receiving a SYN segment, the server allocates state memory in its half-open connection table (SYN Backlog Queue). Attackers barrage the host with spoofed SYN packets and withhold the final ACK, overflowing connection state tables until legitimate handshakes are dropped.

🛡️ **GRC Auditor Perspective:** Enable SYN Cookies on load balancers and firewalls (encoding state parameters into the initial sequence number without consuming memory allocations); reduce half-open timeout thresholds; and enforce SYN rate-limiting rules.

⚠️ **How CompTIA Tests This:** Trigger: 'flood of TCP SYN requests with spoofed IPs leaves half-open connections exhausting server memory'. Answer: SYN Flood. Primary mitigation: SYN Cookies.

📌 NTP/DNS Amplification & Reflection Attacks

🏠 **Real-World Analogy:** It is like an attacker sending a tiny postcard to a public library asking: 'Please mail the complete unabridged encyclopedia collection to my home address', while forging the victim's return address on the postcard. The library dispatches 30 freight delivery trucks loaded with heavy books to the victim's driveway. The victim's property is physically overwhelmed by an avalanche of packages they never requested, triggered by a tiny 10-word postcard.

🔍 **Root Cause & Background:** Stateless UDP protocols (DNS, NTP, SNMP) do not validate source IP origins. Misconfigured publicly reachable servers (open DNS resolvers, NTP servers supporting the legacy `monlist` query) answer tiny 50-byte inquiries with massive 4,000-byte responses directed at the victim's forged source IP.

🛡️ **GRC Auditor Perspective:** Disable legacy NTP debugging commands (`monlist`); restrict DNS servers from acting as open recursive resolvers; and verify upstream ISPs implement BCP 38 ingress/egress filtering to drop spoofed packets.

⚠️ **How CompTIA Tests This:** Trigger: 'small spoofed UDP requests generate disproportionately large response payloads flooding the victim IP' -> Amplification / Reflection Attack (commonly abusing NTP monlist or DNS ANY queries).

📌 Bandwidth Saturation vs. Resource Exhaustion

🏠 **Real-World Analogy:** Bandwidth Saturation (Volumetric DoS) is like clogging the access highway leading to a warehouse with thousands of dumped gravel trucks until no delivery van can approach the gates (the data pipe is overwhelmed). Resource Exhaustion (Application DoS) is when the highway is totally clear, but an adversary opens thousands of heavy background database queries or half-open requests (like Slowloris), pinning server CPU and RAM at 100% until the operating system crashes.

🔍 **Root Cause & Background:** Volumetric attacks exhaust physical transit link throughput (Gbps). Conversely, application-layer resource exhaustion attacks send low-rate, highly complex transactions (such as Slowloris or heavy database calls) to deplete OS sockets, memory pools, and CPU execution threads.

🛡️ **GRC Auditor Perspective:** For bandwidth saturation: deploy Anycast routing and cloud transit scrubbing centers. For resource exhaustion: implement Web Application Firewall (WAF) transaction rate limiting, enforce aggressive idle timeouts, and monitor CPU/thread saturation thresholds.

⚠️ **How CompTIA Tests This:** Trigger: 'incoming link capacity is fully consumed by Gbps of flood traffic' -> Bandwidth Saturation. Trigger: 'low-bandwidth attack holding open HTTP connections until web server connection pool is depleted' -> Resource Exhaustion (e.g., Slowloris).

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Hundreds of thousands of compromised global IoT devices blast simultaneous traffic to bring down an online service	**DDoS / Botnet**
Attacker floods server with TCP SYN packets without returning the final ACK, overflowing connection state tables	**SYN Flood**
Defense mechanism against SYN Floods encoding connection parameters into the sequence number avoiding memory allocation	**SYN Cookies**
Small spoofed UDP query to third-party open servers generates disproportionately large responses directed at the victim	**Amplification / Reflection Attack**
Low-bandwidth attack slowly transmitting HTTP headers to keep connections alive until server threads are exhausted	**Application Resource Exhaustion (e.g., Slowloris)**
Legacy NTP query command historically exploited by threat actors to generate high amplification factors	**NTP monlist**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

An online retailer's website becomes unreachable during a peak sales period. The NOC reports inbound traffic from thousands of unique public IP addresses across multiple countries, all requesting the same product pages. No single source IP dominates the traffic. Which type of attack is most likely occurring?

A) A reflected DNS amplification attack

B) A distributed denial-of-service (DDoS) attack

C) A TCP SYN flood

D) An ICMP echo flood

QUESTION 2 · EXAM SCENARIO

A security analyst notices that an organization's public DNS server is receiving many small queries with spoofed source IP addresses set to a victim's IP address. The server sends large DNS responses to the victim, saturating the victim's internet link. Which technique is being used?

A) TCP SYN flood

B) ICMP ping flood

C) DNS reflection/amplification attack

D) HTTP slow POST attack

QUESTION 3 · EXAM SCENARIO

A web server's connection table is full of half-open TCP connections. Clients are sending SYN packets but never completing the three-way handshake, preventing legitimate users from connecting. Which attack is described?

A) SYN flood attack

B) DNS amplification attack

C) ICMP flood attack

D) Slowloris attack

QUESTION 4 · EXAM SCENARIO

A branch office router experiences high CPU utilization. Network monitoring shows a large volume of ICMP echo requests arriving from many different internet hosts, and the router is replying to each request. Which attack is most likely?

A) SYN flood

B) DNS amplification

C) ICMP flood

D) HTTP flood

QUESTION 5 · EXAM SCENARIO

A gaming company's servers are flooded with attack traffic originating from thousands of compromised home routers and IP cameras. The devices receive commands from an external command-and-control server. Which term best describes the collection of compromised devices?

A) Botnet

B) Content delivery network

C) Virtual private network

D) Load balancer

QUESTION 6 · EXAM SCENARIO

A company wants to reduce the impact of a large volumetric DDoS attack against its public website without moving the application to a new data center. Which mitigation is most appropriate?

A) Deploy a content delivery network with DDoS scrubbing and edge caching.

B) Install additional RAM in the web servers.

C) Enable full-disk encryption on the database servers.

D) Rotate SSH keys on the load balancer.

QUESTION 7 · EXAM SCENARIO

An API gateway is being abused by a single authenticated client that sends thousands of requests per second, causing legitimate users to receive errors. The security team wants to limit the number of requests allowed from that client while preserving normal access for others. Which control should be implemented?

A) DNSSEC on the public DNS zone

B) Rate limiting on the API gateway

C) Full-disk encryption on API servers

D) 802.1X on wireless access points

QUESTION 8 · EXAM SCENARIO

An organization discovers that an internet-facing UDP service is being used in an amplification attack. Attackers send spoofed requests to the service, and the service returns large responses to victims. Which mitigation best reduces this specific risk?

A) Disable unnecessary UDP services and apply anti-spoofing ingress filtering.

B) Enable TLS 1.3 for all UDP services.

C) Deploy host-based antivirus on employee laptops.

D) Increase password complexity for service accounts.

QUESTION 9 · EXAM SCENARIO

During a DDoS attack, a company's web servers show normal CPU and memory usage, but the internet connection is completely saturated. Which mitigation is most appropriate for this type of attack?

A) Install additional RAM in the web servers.

B) Use a CDN with DDoS scrubbing and traffic filtering.

C) Enable database indexing for the product catalog.

D) Rotate SSH keys on the load balancer.

QUESTION 10 · EXAM SCENARIO

An online service is suffering an application-layer HTTP flood from a botnet. The requests look like normal page views, but they are arriving at a very high rate and exhausting server resources. Which mitigation strategy is most appropriate?

A) Deploy a web application firewall with rate limiting and place the site behind a CDN.

B) Extend packet capture retention to 90 days.

C) Assign static IP addresses to all internal clients.

D) Enable DNSSEC on internal DNS servers.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — A distributed denial-of-service (DDoS) attack

The key indicator is a high-volume attack from many distinct sources, which is characteristic of a DDoS attack. A DNS amplification attack would show large DNS responses, a SYN flood would show half-open TCP connections, and an ICMP echo flood would primarily be ICMP traffic. DDoS attacks often use a botnet of compromised hosts to overwhelm the target.

Question 2: Option C — DNS reflection/amplification attack

In a DNS reflection/amplification attack, the attacker sends small spoofed queries to open DNS resolvers. The resolvers send larger responses to the spoofed victim IP, amplifying the traffic. A SYN flood targets TCP connection state, an ICMP flood uses echo requests, and a slow POST attack targets application-layer resources.

Question 3: Option A — SYN flood attack

A SYN flood exploits the TCP three-way handshake by sending many SYN packets with spoofed or incomplete source addresses. The server allocates resources for half-open connections until its connection table is exhausted. Slowloris also holds connections open but typically completes the TCP handshake and sends partial HTTP requests.

Question 4: Option C — ICMP flood

An ICMP flood, also called a ping flood, overwhelms a target with ICMP echo requests. When the target replies to each request, its CPU and bandwidth can be exhausted. SYN floods target TCP state, DNS amplification uses spoofed DNS queries, and HTTP floods target web applications.

Question 5: Option A — Botnet

A botnet is a network of compromised devices, often called bots or zombies, controlled by a command-and-control server. Attackers use botnets to launch large-scale DDoS attacks. A CDN distributes content, a VPN provides encrypted remote access, and a load balancer distributes traffic to servers.

Question 6: Option A — Deploy a content delivery network with DDoS scrubbing and edge caching.

A CDN with DDoS scrubbing and edge caching can absorb and distribute volumetric attack traffic across many edge locations, protecting the origin servers. Adding RAM does not address network bandwidth exhaustion. Full-disk encryption protects data at rest, and rotating SSH keys improves access security but does not mitigate volumetric DDoS.

Question 7: Option B — Rate limiting on the API gateway

Rate limiting restricts how many requests a client can make within a specific time window, helping prevent abuse and application-layer DoS. DNSSEC protects DNS integrity, full-disk encryption protects data at rest, and 802.1X controls network access but does not limit API request volume.

Question 8: Option A — Disable unnecessary UDP services and apply anti-spoofing ingress filtering.

Amplification attacks abuse open UDP services that return large responses to spoofed source IPs. Disabling unnecessary UDP services reduces the attack surface, and ingress filtering helps prevent spoofed packets from leaving networks. TLS 1.3 is for TCP-based encryption, antivirus does not stop network amplification, and password complexity does not address spoofed UDP traffic.

Question 9: Option B — Use a CDN with DDoS scrubbing and traffic filtering.

If CPU and memory are normal but the internet link is saturated, the attack is volumetric and targets network bandwidth. A CDN with DDoS scrubbing can filter and distribute malicious traffic before it reaches the origin. Adding RAM, indexing a database, or rotating SSH keys does not address bandwidth saturation.

Question 10: Option A — Deploy a web application firewall with rate limiting and place the site behind a CDN.

An HTTP flood targets the application layer with many seemingly legitimate requests. A WAF can inspect and filter malicious HTTP traffic, rate limiting can control request volume, and a CDN can absorb distributed traffic. Packet capture retention helps forensics but does not stop the attack, static IPs do not mitigate external botnets, and DNSSEC protects DNS integrity.